

API Specification

Base URLs

Local default:

```
http://localhost:8000
```

Deployed API:

```
https://<front-door-hostname>
```

The frontend uses `VITE_API_URL` or defaults to local.

Authentication

Protected endpoints require:

```
Authorization: Bearer <access_token>
```

Admin impersonation optionally adds:

```
X-Impersonate-User: user@example.com
```

The token audience must match the backend `CLIENT_ID`.

Common Error Format

Most errors return:

```
{
  "detail": "Human-readable error message"
}
```

Infrastructure Endpoints

Method	Path	Auth	Purpose
GET	/	No	Basic service status.
GET	/health	No	Health check.
HEAD	/health	No	Health probe.
GET	/docs	No, OAuth capable	Swagger UI.
GET	/whoami	Admin	Region/container diagnostic.

Tenant and User Endpoints

Meth od	Path	Auth	Purpose
GET	/api/tenant/branding	No	Public tenant branding by Origin/Referer/Host.
GET	/api/me	User	Effective user, app roles, admin status, payroll provider.
GET	/api/users	User	Tenant users except current effective user.
GET	/api/tenant/config	User	Tenant locale, currency, theme, domain, categories, award bounds.

Nomination Endpoints

Create Nomination

POST /api/nominations

Request:

```
{
  "BeneficiaryId": 101,
  "Amount": 250,
  "NominationDescription": "Detailed description of specific contribution.",
  "CategoryId": 3
}
```

Response:

```
{
  "Status": "Submitted",
  "Message": "Nomination submitted successfully"
}
```

Pending Approvals

GET /api/nominations/pending

Returns nominations where the effective user is approver and status is pending.

My Approvals

GET /api/nominations/my-approvals

Returns nominations the effective user has approved or rejected.

Approve or Reject

POST /api/nominations/approve

Request:

```
{
  "NominationId": 42,
  "Approved": true,
  "reason": ""
}
```

Reject request:

```
{
  "NominationId": 42,
  "Approved": false,
  "reason": "Does not meet award criteria."
}
```

History

GET /api/nominations/history

Returns nomination history for current effective user.

Certificate

GET /api/nominations/{nomination_id}/certificate

Response:

```
{
  "DownloadUrl": "https://...",
  "Cached": true
}
```

Email Action

GET /api/nominations/email-action?token=<signed-token>
POST /api/nominations/email-action

Used for email approval/rejection links.

HRBP Endpoints

All HRBP endpoints require effective user role **HRBP**.

Method	Path	Purpose
GET	/api/hrbp/queue	Pending HRBP review queue.
POST	/api/hrbp/nominations/{nomination_id}/approve	HRBP approves flagged item and manager flow continues.
POST	/api/hrbp/nominations/{nomination_id}/reject	HRBP rejects flagged item.
GET	/api/hrbp/nominations/{nomination_id}/pair-history	Relationship history for reviewer context.

Decision request:

```
{
  "reason": "Reviewed and approved."
}
```

Admin Endpoints

Admin endpoints require **Award_Nomination_Admin**.

Method	Path	Purpose
GET	/api/admin/audit-logs	Impersonation audit logs.
POST	/api/admin/refresh-fraud-model	Refresh model cache.
GET	/api/admin/fraud-model-info	Fraud model cache/info.
GET	/api/admin/nominations/{nomination_id}/logs	Nomination log/event view.

Analytics Endpoints

All require admin role.

Method	Path	Purpose
GET	/api/admin/analytics/overview	Summary metrics.
GET	/api/admin/analytics/spending-trends?days=30	Spend and count trend.
GET	/api/admin/analytics/departmentspending	Department breakdown.
GET	/api/admin/analytics/top-recipients?limit=10	Top recipients.
GET	/api/admin/analytics/top-nominators?limit=10	Top nominators.
GET	/api/admin/analytics/fraud-alerts?limit=20	Fraud alerts.
GET	/api/admin/analytics/approval-metrics	Approval/rejection metrics.
GET	/api/admin/analytics/diversity-metrics	Distribution metrics.
GET	/api/admin/analytics/category-breakdown	Category count/spend.
GET	/api/admin/analytics/forecast	Review load and budget forecast.

Forecast query parameters:

- **weeks**
- **history_days**
- **annual_budget**
- **confidence**

Integrity Analytics Endpoints

Method	Path	Purpose
GET	/api/admin/analytics/integrity/runs	Available graph/integrity runs.
GET	/api/admin/analytics/integrity/findings?run_id=<uuid>	Findings for run.
GET	/api/admin/analytics/integrity/findings/{finding_id}/export	Excel export.

AI Conversation Endpoints

Method	Path	Purpose
GET	/api/admin/analytics/conversations	List conversations.
GET	/api/admin/analytics/conversations/{conversation_id}/messages	Load messages.
DELETE	/api/admin/analytics/conversations/{conversation_id}	Delete conversation.
PATCH	/api/admin/analytics/conversations/{conversation_id}	Rename conversation.
POST	/api/admin/analytics/ask	Ask analytics question.
POST	/api/admin/analytics/investigate	Run deeper multi-agent investigation.

Ask/investigate request:

```
{
  "question": "Which departments have unusual award concentration?",
  "conversation_id": "optional-existing-conversation-id"
}
```

Payroll Endpoint

Requires [PayrollBP](#).

```
GET /api/payroll/employee-pay?user_id=101&year=2026&month=7
```

Response includes employee profile and payroll entries for the selected month.

Demo Endpoints

Prefix: [/api/demo](#)

Method	Path	Purpose
POST	/api/demo/warmup_database	Warm demo database.
POST	/api/demo/request	Request demo access through Microsoft B2B invitation and branded email.

Demo request payload:

```
{
  "first_name": "Avery",
  "last_name": "Stone",
  "email": "avery.stone@example.com",
  "is_admin": false
}
```

Demo request response:

```
{
  "message": "Thanks! If this email isn't already registered, you'll receive an invitation shortly."
}
```

The endpoint is unauthenticated, rate-limited by IP and email in the database, blocks common personal email domains unless explicitly allowlisted, creates or refreshes a Microsoft B2B invitation, creates the demo user row, optionally assigns the admin app role, and queues `notification.access_requested`.

Internal Endpoints

Method	Path	Auth	Purpose
POST	<code>/api/internal/refresh-fraud-model</code>	X-Internal-Key	Refresh backend fraud model cache after weekly job.
POST	<code>/api/internal/checkPendingHRBPReview</code>	X-Internal-Key	Detect HRBP SLA breaches and publish events.

Webhook Endpoints

Method	Path	Purpose
POST	<code>/api/webhooks/workday/payment-confirmed</code>	Mark payment confirmed and publish payout accepted.
PATCH	<code>/api/nominations/{nomination_id}/payment-status</code>	Update payment status.

Provider-specific payroll webhooks live in `payroll-broker`.